



GUARDIA
CYBERSECURITY SCHOOL

CAHIER DES CHARGES

TeaRoom : Shadows



INTRODUCTION

Nom du projet : TeaRoom

N° du Projet : 8

Nom d'UE : Techniques de sécurisation cryptographique

N° d'UE : UE 6

Date : 14/04/2025 au 30/04/2025

Classe : Bachelor 1ère année Cybersécurité

MODALITÉS

ex. : Groupes de 2 étudiants à former avant le début du projet

CONTEXTE ET DESCRIPTION DU PROJET

TeaRoom est la dénomination sociale d'une entreprise reposant sur un salon de thé. Le "TeaRoom" à proprement parler, possède une application web full-stack où de futurs client(e)s et client(e)s peuvent voir leurs produits (signatures notamment), réserver une table pour le midi ou même commander des gâteaux qu'ils viendront payer sur place, une fois prêts.

L'application full stack est composée d'une application cliente (via le logiciel navigateur en l'occurrence), d'une application fournissant un service d'API (backend) et d'une base de données. Vous vous occuperez des questions de sécurité cryptographique.

En effet compte tenu du règlement général sur la protection des données (RGDP) venu renforcer le CNIL, les données personnelles et plus particulièrement les données sensibles, doivent faire l'objet d'une protection renforcée et les choix cryptographiques peuvent se révéler déterminant dans le respect des lois nationales et supranationales en vigueur dans ce domaine. L'entreprise vous a sollicité car elle n'a surtout pas envie que sa responsabilité civile soit engagée en raison d'une fuite de données.

Spécificités

Les spécifiques technologiques

Utilisation exclusive du langage Python pour réaliser les différentes fonctionnalités. L'application full stack (code source via l'application Web du Framework Python Anvil) vous sera donnée sans lesdites fonctionnalités. Il s'agira pour vous de les implémenter.

Les spécifications fonctionnelles

Les voici sous forme de user stories :

- Quand l'utilisateur est sur la page de login, il doit pouvoir s'inscrire afin d'atteindre sa page de session.
- Quand l'utilisateur est sur la page de login, il doit pouvoir s'inscrire afin de se créer un compte puis de s'y connecter.
- Quand l'utilisateur est connecté il doit pouvoir modifier ses données personnelles. Il doit pouvoir supprimer son compte.
- Quand l'utilisateur est connecté il doit pouvoir commander un produit.
- Quand l'utilisateur est connecté, il doit à un moment donné prouver à nouveau son identité afin de rester connecté.
- Quand l'utilisateur se déconnecte, aucune donnée ne doit persister dans la mémoire du navigateur afin d'éviter un spoofing.
- Quand Bob Thomas se connecte, il doit être considéré comme un administrateur et avoir des droits privilégiés sur l'application comme celui de voir l'information des utilisateurs et de pouvoir en supprimer afin de respecter ses droits (droit à l'oubli...).

Les spécifications techniques

Les objectifs de la cryptographie doivent être pris en compte (Confidentialité, Intégrité, Disponibilité - CIA).

Il s'agira dans un premier temps de s'intéresser au type de chiffrement à utiliser compte tenu de certains objectifs de performance de l'application. Le choix d'un chiffrement au détriment d'un autre devra être justifié. L'impact des modes de chiffrement devra être pris en compte. Concernant vos clés de chiffrement, elles devront être obfusquées avec des algorithmes faibles de votre choix.

Par ailleurs, concernant Bob Thomas, il s'agira de garantir totalement son identité avant de lui permettre d'effectuer des opérations critiques sur la base de données.

En outre, la base de données de « tearoom » va stocker notamment la photo du client. Il s'agira alors de garantir l'intégrité de cette donnée pour éviter potentiellement toute stéganographie ultérieure ou plus simplement toute falsification de cette photo durant son temps de rétention.

D'ailleurs, vous utiliserez la stéganographie d'une façon ou d'une autre afin de renforcer la protection de la CIA.

Parallèlement à l'intégrité, il s'agira également de s'intéresser au stockage sécurisé des mots de passe et donc à l'algorithme de hachage le plus adéquat. Vous justifierez vos choix.

Par ailleurs, le mécanisme d'authentification devra être robuste afin d'éviter le plus possible toute usurpation d'identité numérique.

En outre, compte tenu de l'arrivée de l'informatique quantique, il s'agirait de montrer au client que vous avez déjà réfléchi à des moyens de garantir un certain niveau de protection de la CIA. Certains de vos choix actuels doivent prouver leur valeur à venir en dépit de la superposition qui va de pair avec les Qubits.

Enfin, vous émettrez des propositions et des recommandations justifiées relatives aux protocoles réseau, notamment en matière de sécurité cryptographique et de certificats numériques dans le cadre du déploiement de l'application sur Internet.



OBJECTIFS PÉDAGOGIQUES ET PROFESSIONNELS DU PROJET

A l'issue de ce projet, les étudiants seront capables de (Veuillez trouver les verbes actifs et mesurables dans cette [infographie](#)) :

Savoirs

- Justifier techniquement le choix d'un algorithme de chiffrement
- Justifier techniquement le choix d'un algorithme de hachage
- Connaître les limites des solutions renforcement la confidentialité, l'intégrité et l'authenticité des données notamment dans le contexte de l'éveil de l'informatique quantique

Savoir-être

- Planifier le bon déroulement du projet
- Travailler en groupe

Savoir-faire / Compétences

- Implémenter des algorithmes de chiffrement dans un contexte déterminé(application Python Full-Stack via Framework Anvil)
- Implémenter des algorithmes de hachage dans un contexte déterminé (application Python Full-Stack via Framework Anvil)

RESSOURCES

1. **A savoir/à apprendre** (Ce travail pourra être évalué / noté en début de projet) :

- Python
- Git
- Anvil

2. **A lire/à consulter :**

- <https://anvil.works>

3. A installer/pré-requis techniques :

- Avoir un compte github

TRAVAIL PRÉPARATOIRE

Nous allons nous servir de Python pour tout ce qui va concerner une grande partie des techniques de cryptographie que je vous demanderai d'implémenter dans le projet. Autrement dit connaître les fondamentaux de Python voir quelques petites bibliothèques pourraient vous faire gagner du temps. Vous mettrez vos différents projets de code dans un dépôt Github public afin que je puisse voir votre niveau d'implication dans la compréhension de Python.



INTERVENANT



Nom : Boris Rose

Titre : Concepteur Logiciel

Email : boris.rose.dev@gmail.com

LinkedIn : <https://www.linkedin.com/in/boris-rose>

BIOGRAPHIE

Pas aussi mystérieux que le personnage de l'image ci-dessus, j'ai tout simplement fait de l'informatique pour le plaisir de programmer, de créer des choses via le code et de continuer d'apprendre dans cet écosystème très enrichissant aussi bien intellectuellement que techniquement. Je suis passé par 42 en 2014 mais je n'avais pas encore compris son intérêt je n'ai pas fait plus que la piscine. J'ai continué seul, je me suis formé, j'ai lu beaucoup de livres, ah ah ! la lecture c'est magique, j'ai testé ... Fait des petits debugs pour les gens à droite et à gauche, avant de commencer à vraiment mettre la main sur des applications full-stack qui m'ont donné du fil à retordre mais c'était chouette, le temps, les nuits, le stress, au final toutes ces choses nous apprennent sur nous-mêmes et sur le niveau de passion qu'on peut ou doit avoir pour exercer ce métier. J'ai fini par obtenir quelques diplômes rétroactivement à ma vie professionnelle, notamment quand j'ai souhaité devenir formateur à temps plein en 2021. Je travaille ainsi en freelance pour quelques écoles d'informatique plus ou moins connues (efrei, supinfo, hetic, ipssi, esgi ...). Dans des domaines de l'informatique assez divers : cybersécurité, architecture réseaux, architecture cloud, logiciel web ... Cependant on va dire que dans tout cela j'ai une préférence pour le design (ux/ui) et les moyens d'automatiser les processus de maintenance des applications et des réseaux ((net)devops)



ROADMAP

DESCRIPTION

Veillez trouver ci-dessous une description des livrables attendus ainsi que les dates d'échéance associées. Il est essentiel de respecter les échéances suivantes pour assurer une progression harmonieuse et structurée du projet. Chaque livrable représente une étape importante dans le processus de réalisation et permet d'évaluer l'avancement du travail. Les dates limites fixées doivent être rigoureusement respectées afin de garantir une évaluation équitable et de permettre un feedback constructif en temps opportun.

Jalon	Livrables attendus	Date limite	Moyens / formats
1	Travail préparatoire	15 avril	Lien du dépôt Github
3			
4	Projet final	10 mai	
5	Bilan du projet		



EVALUATION

L'évaluation est conçue pour être holistique, prenant en compte non seulement le produit final, mais aussi le processus, les compétences acquises et les attitudes démontrées tout au long du projet. Les compétences sont classées en trois catégories principales : "savoirs" (connaissances théoriques), "savoir-faire" (compétences pratiques), et "savoir-être" (compétences interpersonnelles et attitudes).

SYSTÈME DE NOTATION

Savoirs (Connaissances)

- **Compréhension théorique** : Évaluée soit en amont du projet pendant la semaine théorie soit lors de la soutenance et restitution du projet. Cela permet de mesurer la compréhension des concepts fondamentaux et des connaissances liées au projet des étudiants.

Savoir-faire (Compétences)

- **Compétences techniques et application** : Évaluées à travers la soumission finale du projet. Cela inclut la qualité, la fonctionnalité, et la précision technique du travail produit.
- **Gestion de projet** : Évaluée en fonction de l'organisation, du respect des échéances, et de l'utilisation efficace des ressources. Cela peut être évalué à travers la documentation du projet et les journaux de processus.

Savoir-être (Attitudes/Compétences interpersonnelles)

- **Travail d'équipe et collaboration** : Évalués à travers des évaluations par les pairs et les membres du groupe. Les critères incluent la communication, la coopération, et la contribution aux tâches du groupe.
- **Autonomie et initiative** : Évaluées en fonction des contributions individuelles, de la capacité à travailler de manière autonome, et de la résolution proactive des problèmes.
- **Soutenance** : Évaluées lors de la présentation finale du projet. Les critères incluent la clarté, la cohérence, et la capacité à articuler et défendre les résultats du projet.



GRILLE EVALUATION

NOM / PRENOM de l'étudiant :

CLASSE :

Connaissances / Compétences	Barème
Capacité à prendre en compte les limites des algorithmes de chiffrement et de hachage	2
Capacité à éviter le reverse engineering des clés intégrés aux applications	3
Capacité à écrire une logique de code simple, facile à comprendre du côté du frontend et du backend (modules, principes SOLID)	3
Capacité à implémenter une logique de stockage sécurité des mots de passe et à justifier ce choix dans ses avantages et limites	2
Capacité à justifier l'intérêt d'un certificat numérique tout en énonçant ses limites	2
Capacité à préserver la confidentialité et l'intégrité du code en justifiant l'utilisation d'algorithmes de hachage et de chiffrement	3
Capacité à travailler en groupe avec un esprit bienveillant et d'entraide	3
Capacité à utiliser des outils de gestion de projet encourageant la productivité et le professionnalisme	2
TOTAL	20

Appréciation :